CS 474 — Computer Security · Class 10 · Module 08

Guarding the Perimeter & the Web

Network / Web Security & Computer Security Software

Thursday, November 26, 2026 · Hour 1 — five lessons, 60 minutes

Block: Security Domains & Technologies · Reading: Easttom Ch. 9 + Ch. 2 + the **OWASP** (Open Worldwide Application Security Project) Top 10 handout · **LO** (Learning Outcome) 1, 2, 5

Cyber.SoHo Educational Hub · Legal Notice, Terms of Use and Acceptable Use Policy (click to open)

Today: from understanding BlueFern to defending it

- Milestone 1 and the Mid-Term are behind you: BlueFern's assets, network, attackers, scan results, malware, incident response and cryptography
- Today we **build the defences** where the Class 4 scan found the worst problems: the network edge, remote and wireless access, the web shop
- The last new-content lecture: **Research Sprints** on December 3, 10 and 17; review, showcase and Final in January
- Hours 2–3: target architecture, web-shop checklist and security-software choice — **Binder Part 8**

1. **Lesson 1 · Firewalls & segmentation**
2. **Lesson 2 · Remote access & Wi-Fi**
3. **Lesson 3 · Web-application security**
4. **Lesson 4 · Security software**
5. **Lesson 5 · Target architecture & Sprints**

Scope. Computer-security course: controls are configured only on systems you are authorized to protect. The five simulators run in your browser and send nothing (Legal Notice 6, 7.2, 7.4).

By the end of this hour you will be able to

1. Apply **first match** and **implicit deny**; tell a packet filter, a stateful firewall, an **NGFW** (Next-Generation Firewall) and a **WAF** (Web Application Firewall) apart
2. Place a **DMZ (Demilitarized Zone — also called a screened subnet)**, a private database subnet and **VLANs (Virtual Local Area Networks)** on BlueFern's map, with the rules between them
3. Choose a remote-access or site-to-site **VPN (Virtual Private Network)**, explain **MFA (Multi-Factor Authentication)** on it, secure Wi-Fi with **WPA3 (Wi-Fi Protected Access 3)** and separate **SSIDs (Service Set Identifiers)**
4. Recognize injection, **XSS** (Cross-Site Scripting), authentication failures and misconfiguration, and name the control for each
5. State what antivirus, **EDR** (Endpoint Detection and Response), **IDS** (Intrusion Detection System), **IPS** (Intrusion Prevention System), **SIEM** (Security Information and Event Management), password managers and patch tools prevent — and miss
6. Build a **control-to-threat table** and explain how the three Research Sprints run

Lecture plan — 60 minutes

	Lesson	Talk	Micro-activity	Activity
—	Overview — from understanding BlueFern to defending it	2	—	—
1	Firewalls and segmentation	10	Visualization — redraw the map	3
2	Remote access and Wi-Fi	8	Flash-cards — six terms	3
3	Web-application security	12	Practical — the parameterized query	4
4	Computer security software	7	Fun quiz — which tool for which job?	2
5	Target architecture and the Research Sprints	5	Sprint check + Zen break	4
	Total	**44**		**16 → 60 min**

The one FACT: your weekly work IS the project, and the project IS your exam preparation. **Binder Part 8** is due **Wednesday, December 2, 2026, 23:59** — **LO** (Learning Outcome) 5: map controls to risks.

LESSON 1 · 10 MINUTES OF TALK + 3 MINUTES OF ACTIVITY

1 Firewalls and segmentation

Packet filters, stateful firewalls, **NGFW** (Next-Generation Firewall), **WAF** (Web Application Firewall), **DMZ** (Demilitarized Zone — also called a screened subnet) and **VLANs** (Virtual Local Area Networks)

Objective. Explain what a firewall decides and on which information, distinguish the four firewall families, and place a **DMZ** (Demilitarized Zone — also called a screened subnet) and **VLANs** (Virtual Local Area Networks) on BlueFern's network so that each zone talks only to the zones it needs.

1 What a firewall decides

- A **firewall** sits at the boundary between networks and takes one decision per packet or connection: **allow** or **deny**
- It compares the traffic with the **rules** of the **firewall policy** — **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-41 Rev. 1
- A basic rule sees the **five-tuple**: source and destination **IP** (Internet Protocol) address, protocol, source and destination port
- **First match decides**: rules are read from top to bottom
- **Implicit deny** ends the list; a broad allow above a specific deny is a **shadowed rule**
- **Egress filtering**: a web server may reach its update servers only — a compromised server cannot call the attacker back

Packet: Internet 192.0.2.66 → 203.0.113.25, **TCP** (Transmission Control Protocol) port 3306

R3 allows 3306 only from the web server, so no allow rule matches — the **implicit deny** drops the packet.

#	Action	Source	Destination	Port
R1	allow	Internet	web application firewall	443
R2	allow	web application firewall	web server	443
R3	allow	web server	database	3306
R4	allow	remote-access pool	web server	22
—	**deny**	**any**	**any**	**any**

1 Stateless or stateful?

Packet filter (stateless)

- Examines each packet **in isolation** — header fields only
- Fast, little memory: router **ACLs** (Access Control Lists), cloud network **ACLs** (Access Control Lists)
- Needs a broad return rule: “source port 443 → ports 1024–65535”
- A forged packet from port 443 passes that rule — even to MySQL on 3306
- Cannot see inside the packet

Stateful firewall

- Keeps a **state table** of allowed connections (five-tuple + **TCP** (Transmission Control Protocol) state)
- Later packets match the table; only **new** connections are compared with the rules
- No return rule needed: the forged reply has no entry and is dropped
- Default in Windows Defender Firewall, Linux nftables and cloud security groups
- Still decides by address, port and state — port 443 can carry anything

1 The next-generation firewall (NGFW) and the UTM (Unified Threat Management)

An **NGFW** (Next-Generation Firewall) adds four capabilities to stateful inspection:

Application identification

Recognizes the application from the content, whatever the port: cloud e-mail allowed, file sharing refused — both on 443

User identity

Rules use directory groups — “finance” — instead of **IP** (Internet Protocol) addresses

Integrated intrusion prevention

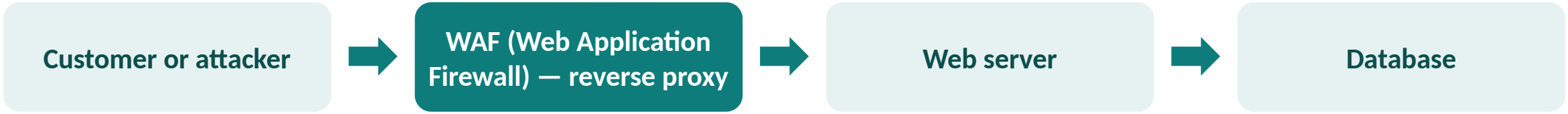
Applies the attack signatures you met in Class 6

URL (Uniform Resource Locator) categorization

Blocks whole categories of websites

TLS (Transport Layer Security) inspection ends the encrypted session and opens a new one with a company certificate: announce it in the acceptable use policy and exclude banking and health sites. A **UTM (Unified Threat Management)** is the older all-in-one box for small offices.

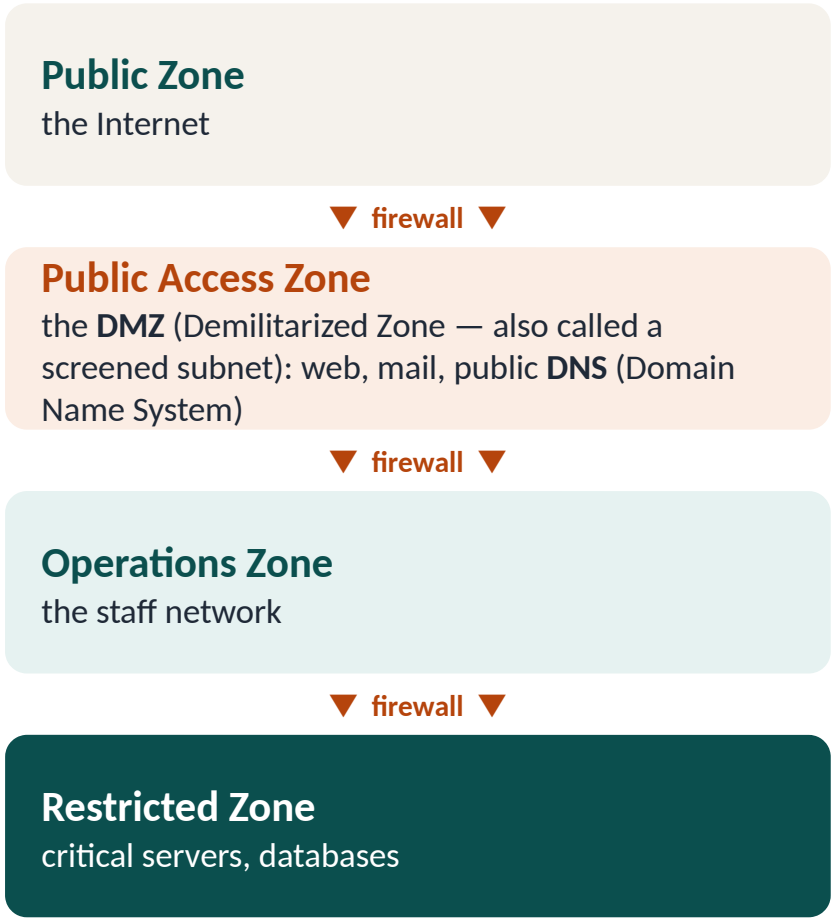
1 The web application firewall (WAF)



*The **WAF** (Web Application Firewall) reads every **HTTP** (Hypertext Transfer Protocol) request and response before the web server does*

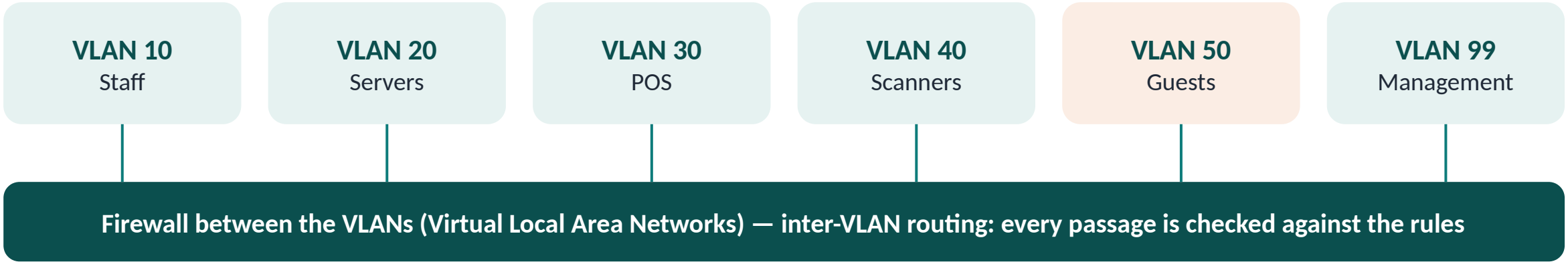
- Recognizes **SQL** (Structured Query Language) injection, cross-site scripting and path traversal inside form fields and **URLs** (Uniform Resource Locators)
- Limits the request rate of a client; applies a **virtual patch** while the code is corrected
- Reverse proxy, web-server module (ModSecurity, Coraza) or cloud service; many use the **OWASP** (Open Worldwide Application Security Project) **CRS** (Core Rule Set) rules
- Limits: it does not correct the application, attackers look for encodings it misses, and it raises **false positives**
- **PCI DSS** (Payment Card Industry Data Security Standard) version 4 asks for such a solution in front of public web applications — Research Sprint 2

1 Segmentation — zones and the DMZ (Demilitarized Zone — also called a screened subnet)



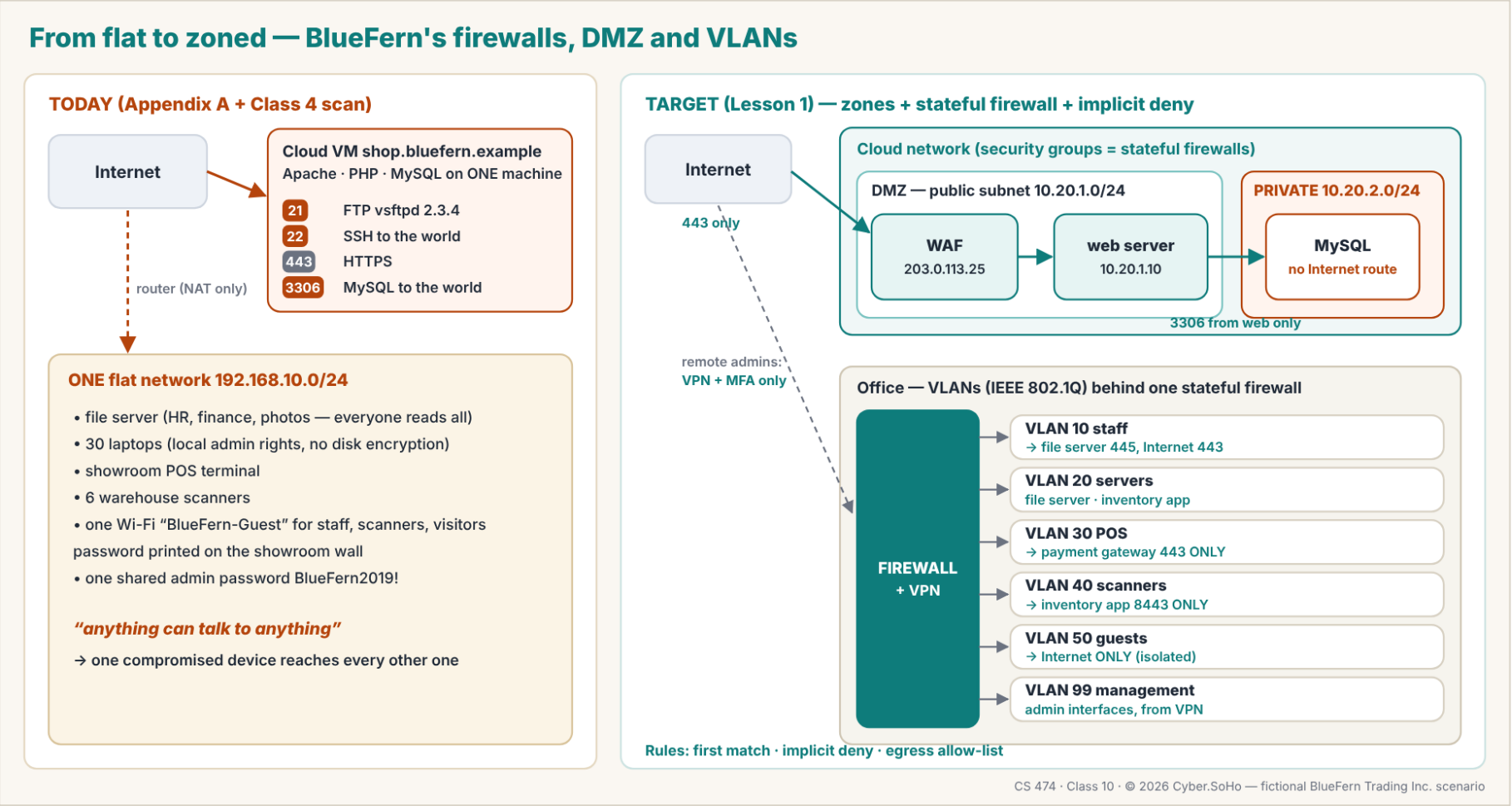
- **Segmentation** places a firewall at every passage between **zones** and limits **lateral movement** (zones of ITSG-38)
- The **DMZ (Demilitarized Zone — also called a screened subnet)** holds only what must accept connections from the Internet
- Strict in three directions: Internet → published ports only; **DMZ** (Demilitarized Zone — also called a screened subnet) → internal only exact flows; internal → **DMZ** (Demilitarized Zone — also called a screened subnet) administration only via the **VPN** (Virtual Private Network)
- BlueFern's cloud: **WAF** (Web Application Firewall) and web server in a public subnet, MySQL in a **private subnet** reachable only from the web server on 3306, **SSH** (Secure Shell) only from the **VPN** (Virtual Private Network), **FTP** (File Transfer Protocol) removed

1 VLANs (Virtual Local Area Networks) — one switch, several networks



- A **VLAN (Virtual Local Area Network)** (**IEEE** (Institute of Electrical and Electronics Engineers) 802.1Q) splits one physical switch into logical networks — a 12-bit tag, 4,094 usable numbers
- Devices in different **VLANs** (Virtual Local Area Networks) cannot exchange frames directly: traffic passes a router or firewall — **inter-VLAN routing**
- The **VLAN** (Virtual Local Area Network) separates; the firewall between the **VLANs** (Virtual Local Area Networks) secures
- **Microsegmentation** pushes zones down to each server; **zero trust** (**NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-207) trusts no request because of its network

1 Schematic 1 — from flat to zoned

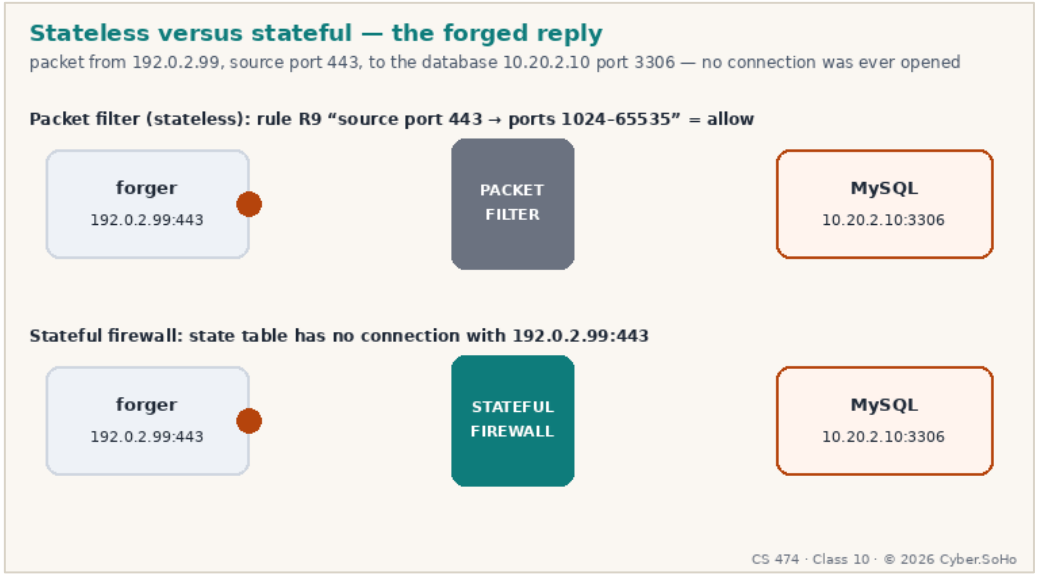


Left: today's single flat network and a web shop with **FTP** (File Transfer Protocol), **SSH** (Secure Shell) and MySQL open to the Internet. Right: the cloud **DMZ** (Demilitarized Zone — also called a screened subnet) (**WAF** (Web Application Firewall) and web server in a public subnet, MySQL in a private subnet), the office firewall with **VLANs** (Virtual Local Area Networks) 10–99, and the **VPN** (Virtual Private Network) as the only path for administration.

1 Example 1 — closing the open ports of the web shop

What happens — and where it goes next

- Scan report: vsftpd 2.3.4 on 21, OpenSSH 7.2 on 22 and MySQL 5.5 on 3306 — open to the whole Internet
- Nine allow rules + implicit deny; fourteen captured connection attempts replayed
- Both firewalls give the same decisions except packet 14: the forged reply to 3306 passes the stateless return rule and is dropped by the stateful firewall
- Deliverable → Exercise 10.1 (control-to-threat table), Research Sprint 2 (**POS** (Point of Sale) and payment rules), the showcase



Animation 1 — Stateless versus stateful — the forged reply (plays in slide-show mode)

▶️ Interactive example 1 — First-match firewall simulator — stateless versus stateful

`CS474_Class10_Example1_firewall_simulator.html`

Self-contained **HTML** (HyperText Markup Language): Copy · Start / Pause · Step · Restart; runs offline and sends nothing

1 Micro-activity 1 — redraw the map (3 min)

- On the board: today's BlueFern — the cloud web shop with **FTP** (File Transfer Protocol), **SSH** (Secure Shell) and MySQL open, the office router, one flat network 192.168.10.0/24
- The class places: the **WAF (Web Application Firewall)**, the **DMZ (Demilitarized Zone — also called a screened subnet)**, the database's **private subnet**, the office **VLANs (Virtual Local Area Networks)** and the firewall between them
- For each element, one sentence: **why there?**

Videos — 15 minutes or less, checked November 14, 2026

▶️ **Firewall Types - CompTIA Security+ SY0-701 - 3.2**
Professor Messer · 8:00 · Watch on YouTube ↗

▶️ **Firewalls - CompTIA Security+ SY0-701 - 4.5**
Professor Messer · 11:31 · Watch on YouTube ↗

▶️ **Network Infrastructure Concepts - CompTIA Security+ SY0-701 - 3.1**
Professor Messer · 6:56 · Watch on YouTube ↗

LESSON 2 · 8 MINUTES OF TALK + 3 MINUTES OF ACTIVITY

2 Secure remote access and wireless

VPN (Virtual Private Network) types, **MFA** (Multi-Factor Authentication) on the **VPN** (Virtual Private Network), **WPA2** (Wi-Fi Protected Access 2) and **WPA3** (Wi-Fi Protected Access 3), guest isolation, rogue access points

Objective. Choose the right **VPN** (Virtual Private Network) type for a remote user and for a site, explain why **MFA** (Multi-Factor Authentication) belongs on the **VPN** (Virtual Private Network), and secure a small company's Wi-Fi with **WPA3** (Wi-Fi Protected Access 3), separate networks, guest isolation and rogue-AP detection.

2 VPN (Virtual Private Network) — two types, three protocol families

- A **VPN (Virtual Private Network)** builds an encrypted, authenticated **tunnel** across an untrusted network; the **VPN (Virtual Private Network) gateway** ends the tunnels
- **Remote-access**: one device to the company; **site-to-site**: two networks, gateway to gateway
- **IPsec (Internet Protocol Security)** (**IKEv2** (Internet Key Exchange version 2) + **ESP** (Encapsulating Security Payload), tunnel mode — **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-77), **TLS (Transport Layer Security) VPN (Virtual Private Network)** on port 443, **WireGuard**
- **Full tunnel**: all traffic passes the company's filtering; avoid **split tunnel** (**ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).80.101)
- **ZTNA (Zero Trust Network Access)**: access to one application at a time, after checking the user and the device

Remote access — one device



Site-to-site — two networks



Full tunnel or split tunnel?

Full: all traffic → the company's filtering and logs

Split: only company traffic; the rest goes directly to the Internet

2 MFA (Multi-Factor Authentication) on the VPN (Virtual Private Network) — and the device that connects

- The gateway faces the whole Internet: with a password alone, credential stuffing and phishing are enough
- **ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).80.101: **MFA (Multi-Factor Authentication)** on the **VPN** (Virtual Private Network), **phishing-resistant** factors, a patched gateway
- **Posture check** by the **VPN** (Virtual Private Network) client or a **NAC** (Network Access Control) system: managed laptop, encrypted disk, current patches, endpoint protection
- BlueFern rule: company laptops with always-on **VPN** (Virtual Private Network) → internal shares; personal devices → webmail only

FIDO2 (Fast IDentity Online 2) key or passkey

Phishing-resistant — bound to the real site's name

Number matching

The user types the number shown at login — no accidental approval

Plain push prompt

Exposed to **MFA (Multi-Factor Authentication) fatigue**: prompt after prompt until one is approved

2 Wi-Fi security — WPA2 (Wi-Fi Protected Access 2) and WPA3 (Wi-Fi Protected Access 3)

	WPA2 (Wi-Fi Protected Access 2) Personal	WPA2 (Wi-Fi Protected Access 2) Enterprise	WPA3 (Wi-Fi Protected Access 3) Personal
Authentication	one shared **PSK** (Pre-Shared Key) — the Wi-Fi password	802.1X with **EAP** (Extensible Authentication Protocol) and a **RADIUS** (Remote Authentication Dial-In User Service) server: own credentials	**SAE** (Simultaneous Authentication of Equals) key exchange
Offline password guessing	possible from one recorded handshake	no shared password to guess	not possible
Other people's sessions	decryptable with the **PSK** (Pre-Shared Key) and their handshake	separate keys per user	independent key per session
Removing one person	change the password for everyone	revoke one credential	change the password
Extras	—	—	**PMF** (Protected Management Frames) required; **WEP** (Wired Equivalent Privacy) and **TKIP** (Temporal Key Integrity Protocol) refused

Guest networks: **Wi-Fi Enhanced Open** (**OWE** (Opportunistic Wireless Encryption)) encrypts each guest without a password — but authenticates nobody.
Reference: **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-153.

2 One SSID (Service Set Identifier) per level of trust

BlueFern-Staff

WPA3 (Wi-Fi Protected Access 3) Enterprise, 802.1X

VLAN (Virtual Local Area Network) 10

Reaches: file server, Internet

BlueFern-Scan

Enterprise, device certificates

VLAN (Virtual Local Area Network) 40

Reaches: inventory application only

BlueFern-Guest

WPA3 (Wi-Fi Protected Access 3) Personal, weekly password (or Enhanced Open)

VLAN (Virtual Local Area Network) 50

Reaches: Internet only, client isolation

- Today: one **SSID** (Service Set Identifier) for staff, scanners and visitors; the password is printed on the showroom wall; behind it, the flat network with the file server and the **POS** (Point of Sale)
- Two weaknesses, two controls: **WPA3 (Wi-Fi Protected Access 3)** for the password, **separate SSIDs (Service Set Identifiers) on separate VLANs (Virtual Local Area Networks)** for the separation

2 Rogue access points and the evil twin

Rogue AP (Access Point)

A travel router plugged into an office wall socket: an unprotected entry into the internal network

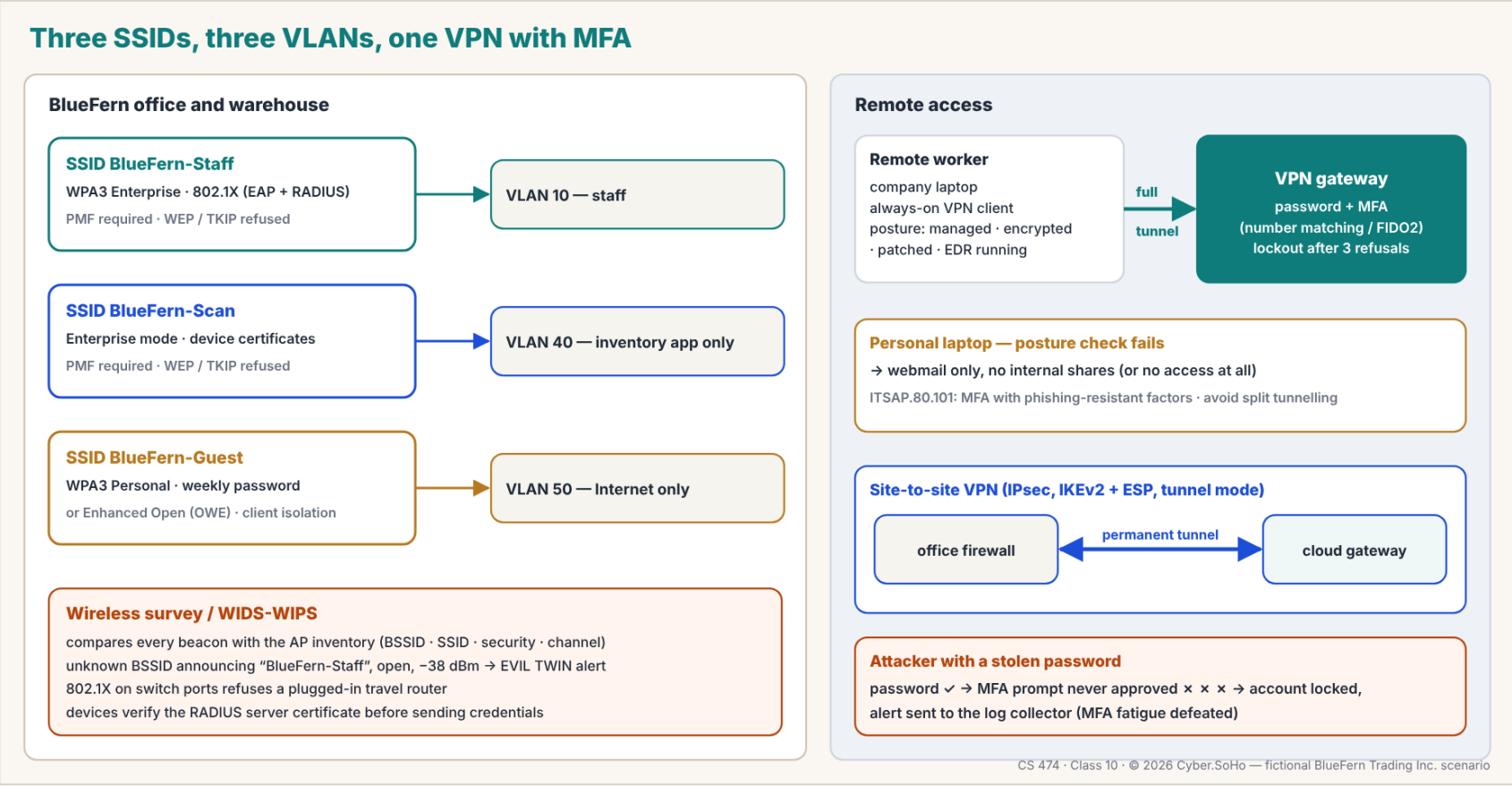
Evil twin

An attacker's **AP** (Access Point) that broadcasts the company **SSID** (Service Set Identifier): traffic and passwords pass through the attacker's equipment

Three measures detect or prevent them

- **Wireless survey** (periodic, or continuous with a **WIDS** (Wireless Intrusion Detection System) or **WIPS** (Wireless Intrusion Prevention System)): every beacon is compared with the inventory — **BSSID** (Basic Service Set Identifier), security mode, channel
- **802.1X on switch ports** refuses an unknown device plugged into a wall socket
- Enterprise Wi-Fi clients **verify the RADIUS (Remote Authentication Dial-In User Service) server certificate**, so credentials never reach an evil twin
- Survey only networks you own or are authorized to monitor — Legal Notice 7.2

2 Schematic 2 — Wi-Fi networks and remote access

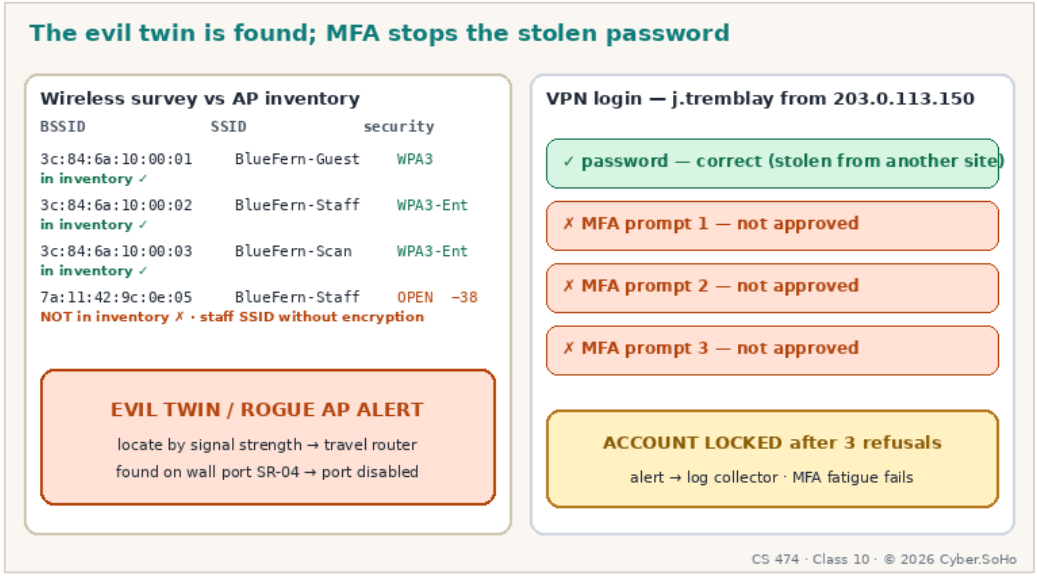


Three **SSIDs** (Service Set Identifiers) on three **VLANs** (Virtual Local Area Networks) behind the firewall, the remote-access **VPN** (Virtual Private Network) with **MFA** (Multi-Factor Authentication) and a posture check, and the wireless survey that finds the evil twin.

2 Example 2 — the password on the showroom wall

What happens — and where it goes next

- 08:30 a visitor's phone joins BlueFern-Guest → **VLAN** (Virtual Local Area Network) 50; its attempt on the file server (445) is refused
- 09:10 the survey sees “BlueFern-Staff” from an unknown **BSSID** (Basic Service Set Identifier) with no encryption → a travel router is found and its port disabled
- 10:40 a stolen password without an approved prompt → denied; 10:41–10:44 fatigue prompts → lockout after three refusals
- 11:20 a personal laptop fails the posture check → webmail only; 13:15 a WPA2-TKIP handheld is refused
- Deliverable → Exercise 10.1 boxes; Research Sprint 2 (leaver procedure)



*Animation 2 — The evil twin is found; **MFA** (Multi-Factor Authentication) stops the stolen password (plays in slide-show mode)*

▶️ Interactive example 2 — Wi-Fi and remote-access policy checker

`CS474_Class10_Example2_wifi_vpn_policy.html`

Self-contained **HTML** (HyperText Markup Language): Copy · Start / Pause · Step · Restart; runs offline and sends nothing

2 Micro-activity 2 — six flash-cards (3 min)

- One card at a time: **stateful firewall · DMZ (Demilitarized Zone — also called a screened subnet) · VPN (Virtual Private Network) · WPA3 (Wi-Fi Protected Access 3) · rogue AP (Access Point) · WAF (Web Application Firewall)**
- The class gives the one-sentence definition before the card turns
- Room question: which two of the six would stop a showroom visitor from reaching the **POS** (Point of Sale) terminal?

Videos — 15 minutes or less, checked November 14, 2026

▶️ **Secure Communication - CompTIA Security+ SY0-701 - 3.2**
Professor Messer · 9:55 · Watch on YouTube ↗

▶️ **Wireless Security Settings - CompTIA Security+ SY0-701 - 4.1**
Professor Messer · 10:54 · Watch on YouTube ↗

▶️ **Securing Wireless and Mobile - CompTIA Security+ SY0-701 - 4.1**
Professor Messer · 8:58 · Watch on YouTube ↗

LESSON 3 · 12 MINUTES OF TALK + 4 MINUTES OF ACTIVITY

3 Web-application security essentials

OWASP (Open Worldwide Application Security Project) Top 10:2025 highlights, input validation, **HTTPS** (Hypertext Transfer Protocol Secure) everywhere, secure cookies and sessions

Objective. Recognize injection, cross-site scripting, authentication failures and security misconfiguration in a web shop, and name the control that removes each: parameterized queries, input validation, output encoding, **HTTPS** (Hypertext Transfer Protocol Secure) with **HSTS** (HTTP Strict Transport Security), secure cookies and sessions, and a hardened configuration.

3 The web shop and the OWASP (Open Worldwide Application Security Project) Top 10:2025

- The only BlueFern system the whole Internet is **supposed** to reach — port 443 must stay open
- An attack inside a valid **HTTPS** (Hypertext Transfer Protocol Secure) request passes every firewall that does not read requests
- The **OWASP (Open Worldwide Application Security Project) Top 10** is an awareness document built from testing data and a community survey
- Today: injection, **XSS** (Cross-Site Scripting) (inside A05), authentication failures, security misconfiguration
- "Broken authentication" (2017) → "Identification and Authentication Failures" (2021) → "Authentication Failures" (2025)

A01 Broken Access Control

A02 Security Misconfiguration

A03 Software Supply Chain Failures

A04 Cryptographic Failures

A05 Injection (incl. XSS (Cross-Site Scripting))

A06 Insecure Design

A07 Authentication Failures

A08 Software or Data Integrity Failures

A09 Security Logging and Alerting Failures

A10 Mishandling of Exceptional Conditions

3 Injection (A05:2025) — when data becomes code

Concatenation — vulnerable

```
query = "SELECT name, price FROM products
         WHERE name LIKE '%" + q + "%'"
```

Input typed into the search box

```
q = x' UNION SELECT email, password_hash FROM customers --
```

Parameterized query — correct

```
db.execute("SELECT name, price FROM products
            WHERE name LIKE ?", ("%" + q + "%",))
```

- Untrusted input pasted into a query changes its **structure** instead of being a **value**
- The quote closes the string, UNION adds a query, the two dashes comment out the rest
- **Parameterized query**: the database parses the query before it receives the value — the value never becomes **SQL** (Structured Query Language)
- Add **allow-list validation** and a **least-privilege database account**; manual escaping is strongly discouraged
- Recognize the pattern — never try it on a real website (Legal Notice 6.3)

3 Cross-site scripting — code in the visitor's browser

XSS (Cross-Site Scripting): untrusted input written into a page without encoding runs in the visitor's browser with the website's full rights.

Stored

Saved — a product review — and served to every visitor of the page

Reflected

Arrives in a link parameter and is echoed to the one person who clicked

DOM-based

The website's own JavaScript copies untrusted data into the page's **DOM** (Document Object Model)

Defences, in this order (OWASP (Open Worldwide Application Security Project) XSS (Cross-Site Scripting) Prevention Cheat Sheet)

1 · **Context-aware output encoding**: < becomes < and > becomes > — the browser shows text instead of running it

2 · An **HTML (HyperText Markup Language) sanitizer** (DOMPurify) when users really must submit **HTML** (HyperText Markup Language)

3 · A **Content Security Policy** header: which scripts the browser may run

4 · **HttpOnly** session cookie: out of reach of JavaScript

3 Authentication failures (A07:2025) and secure sessions

```
Set-Cookie: __Host-sid=8f3a…c41; Secure; HttpOnly; SameSite=Lax; Path=/
```

`Secure`
sent over **HTTPS** (Hypertext Transfer Protocol Secure) only

`HttpOnly`
not readable by JavaScript

`SameSite=Lax`
not sent with requests other sites trigger (**CSRF** (Cross-Site Request Forgery))

`__Host-` prefix
the browser enforces Secure, Path=/ and no Domain

- Typical failures: no defence against **credential stuffing**, default passwords (BlueFern2019!), no **MFA** (Multi-Factor Authentication) for staff, revealing error messages
- The **session ID (Identifier)** is the user for the server: long and random, **regenerated at login** (stops **session fixation**), destroyed at logout, expires when idle
- Login form: rate limiting, breached-password check (**NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-63B-4), **MFA** (Multi-Factor Authentication) for staff, one generic error message
- Secure and HttpOnly: **RFC** (Request for Comments — an Internet standards document) 6265; SameSite: **RFC** (Request for Comments — an Internet standards document) 6265bis — still a draft, implemented by all major browsers

3 HTTPS (Hypertext Transfer Protocol Secure) everywhere — and security misconfiguration

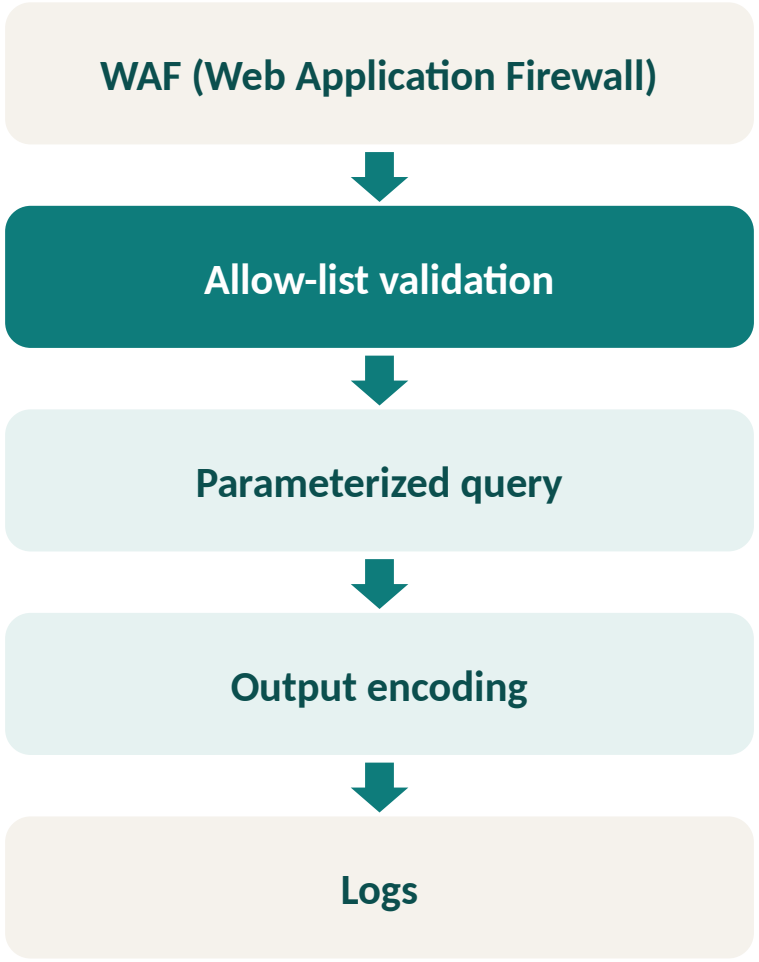
HTTPS (Hypertext Transfer Protocol Secure) everywhere + HSTS (HTTP Strict Transport Security)

- Every page over **HTTPS** (Hypertext Transfer Protocol Secure); a plain **HTTP** (Hypertext Transfer Protocol) request gets a 301 redirect
- Header: Strict-Transport-Security: max-age=31536000; includeSubDomains
- For one year the browser contacts the shop **only** over **HTTPS** (Hypertext Transfer Protocol Secure) (**RFC** (Request for Comments — an Internet standards document) 6797) — no downgrade on café Wi-Fi
- Certificates renewed automatically

Security misconfiguration (A02:2025)

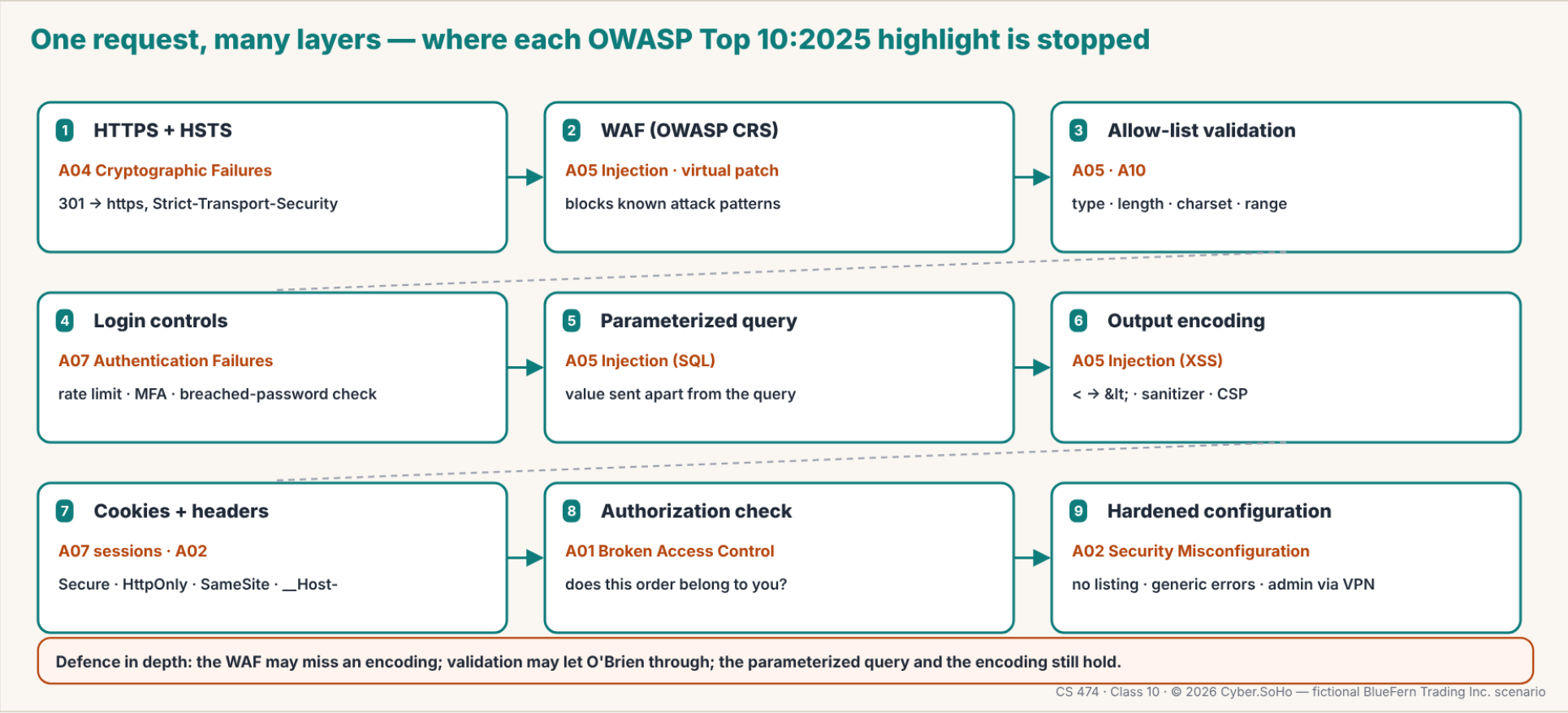
- Default accounts, directory listing, stack traces, unused services, open admin panels, missing headers
- BlueFern: **FTP** (File Transfer Protocol) on, /admin with the shared password, a public uploads folder with an old export
- Fix: a baseline, remove what is not needed, generic errors, security headers, /admin only via **VPN** (Virtual Private Network) + **MFA** (Multi-Factor Authentication), **DAST** (Dynamic Application Security Testing) checks

3 Input validation — the principle under all of it



- Validate **on the server**: browser checks help honest users; attackers skip them
- **Allow-list** per field — order number “BF-” + six digits; quantity 1 to 20; search ≤ 40 letters, digits, spaces, hyphens
- Input that does not match is **rejected**, never repaired; a blocklist always misses an encoding
- Validation does not replace parameterization or encoding: the apostrophe of O'Brien must still pass

3 Schematic 3 — one request, many layers

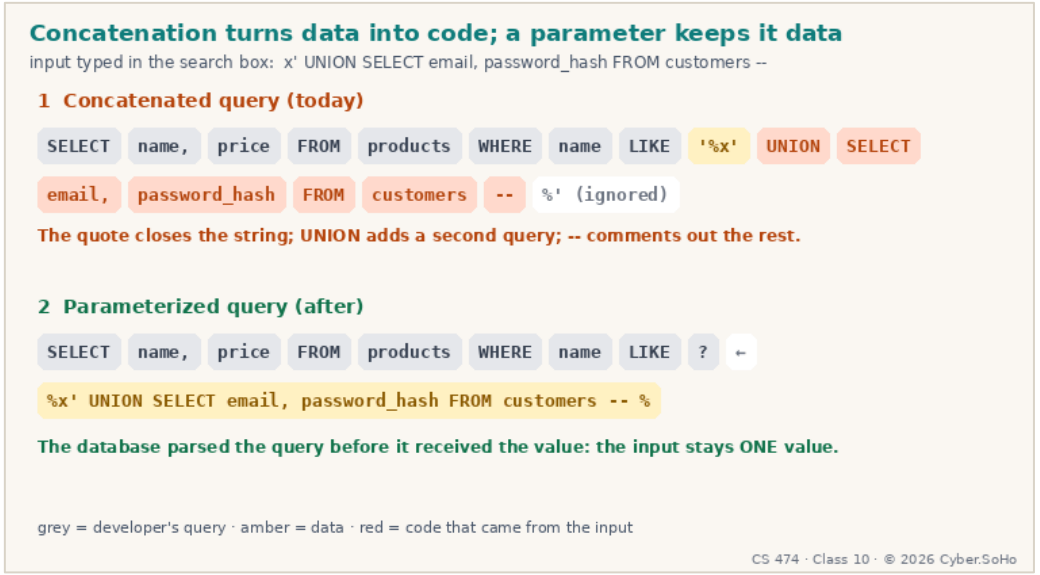


Each **OWASP** (Open Worldwide Application Security Project) highlight is stopped at its own layer — from **HTTPS** (Hypertext Transfer Protocol Secure) and **HSTS** (HTTP Strict Transport Security) at the edge to the hardened configuration at the core.

3 Example 3 — one day of requests, before and after

What happens — and where it goes next

- 08:00 plain **HTTP** (Hypertext Transfer Protocol) → 301 + **HSTS** (HTTP Strict Transport Security); 08:05 an honest search for “boots” → 12 products before and after
- 08:12 the UNION injection → before: e-mails and hashes listed; after: **WAF** (Web Application Firewall), validation and the parameterized query each stop it
- 08:40 a stored **XSS** (Cross-Site Scripting) review → shown as text, HttpOnly cookie, **CSP** (Content Security Policy) refuses inline script
- 10:00 credential stuffing, 600 attempts from 300 addresses → 4 accounts taken before, none after
- Deliverable → Exercise 10.2 checklist; Research Sprint 2 e-commerce review



Animation 3 — Concatenation turns data into code; a parameter keeps it data (plays in slide-show mode)

▶️ Interactive example 3 — Web request inspector — the same request, before and after the controls

`CS474_Class10_Example3_web_request_inspector.html`

Self-contained **HTML** (HyperText Markup Language): Copy · Start / Pause · Step · Restart; runs offline and sends nothing

3 Micro-activity 3 — find the injection (4 min)

```
u = form["user"]
p = form["pass"]
query = "SELECT * FROM users WHERE user = '" + u + "' AND pass = '" + p + "'"
row = db.execute(query).fetchone()
if row: login_ok()
```

- (1) Which value of u logs in as admin without the password?
- (2) Rewrite lines 3 and 4 as a parameterized query
- (3) What else is wrong with this design, even after the fix?

Videos — 15 minutes or less, checked November 14, 2026

▶️ SQL (Structured Query Language) Injection - CompTIA Security+ SY0-701 - 2.3
Professor Messer · 5:09 · Watch on YouTube ↗

▶️ Cross-site Scripting - CompTIA Security+ SY0-701 - 2.3
Professor Messer · 8:34 · Watch on YouTube ↗

▶️ Application Security - CompTIA Security+ SY0-701 - 4.1
Professor Messer · 8:26 · Watch on YouTube ↗

LESSON 4 · 7 MINUTES OF TALK + 2 MINUTES OF ACTIVITY

4 Computer security software

Antivirus, **EDR** (Endpoint Detection and Response), **IDS** (Intrusion Detection System) / **IPS** (Intrusion Prevention System), **SIEM** (Security Information and Event Management), password managers, patch management: capabilities, limits, how to choose

Objective. State what each family of security software protects, what it cannot see, and choose a set that covers prevention, detection, response and recovery for a 38-person company with two **IT** (Information Technology) staff.

4 Antivirus — necessary, not sufficient

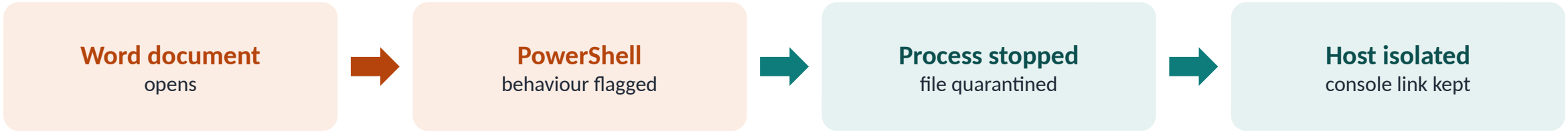
What it does

- Compares files and memory with **signatures** (byte patterns, hash values) and **heuristics**
- Blocks known malware the moment a file is written or started
- Built into modern operating systems — **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-83 Rev. 1
- Stops the large volume of known, commodity malware

What it misses

- A **new or modified variant** — no signature yet
- A **fileless attack** that runs in memory through scripting tools
- **Living off the land**: the administration tools already on the machine
- An attacker with administrator rights can switch it off

4 Endpoint detection and response (EDR) — and XDR (Extended Detection and Response)



- **EDR (Endpoint Detection and Response)** records each process, command line, file change and connection on every laptop and server
- It detects **malicious behaviour** whatever the file — 2,000 files renamed in a minute, a process reading the login service's memory
- It responds in seconds — Class 5's “isolate first” — and gives the investigator a timeline
- **XDR (Extended Detection and Response)** correlates endpoints, e-mail, network and cloud
- Limits: alerts need a reader (an **MDR** (Managed Detection and Response) service for small teams); an administrator may stop the agent; per-endpoint licence

4 Intrusion detection and prevention, and the SIEM (Security Information and Event Management)

Network IDS (Intrusion Detection System) / IPS (Intrusion Prevention System)

- The **IDS** (Intrusion Detection System) watches a copy of the traffic and alerts; the **IPS** (Intrusion Prevention System) sits in the path and blocks
- BlueFern: the sensor at the inter-VLAN firewall sees a laptop scanning port 445 in the server **VLAN** (Virtual Local Area Network)
- Limits: no view inside encrypted traffic unless it is decrypted; sees only its segments

SIEM (Security Information and Event Management) (+ SOAR (Security Orchestration, Automation and Response))

- Collects firewall, **VPN** (Virtual Private Network), **WAF** (Web Application Firewall), web-server, **EDR** (Endpoint Detection and Response) and identity logs; normalizes, correlates, alerts
- A **SOAR** (Security Orchestration, Automation and Response) platform adds automated responses
- Limits: only as good as its logs and rules; **alert fatigue** — a **SIEM** (Security Information and Event Management) nobody reads is not a control

4 Password managers and patch management

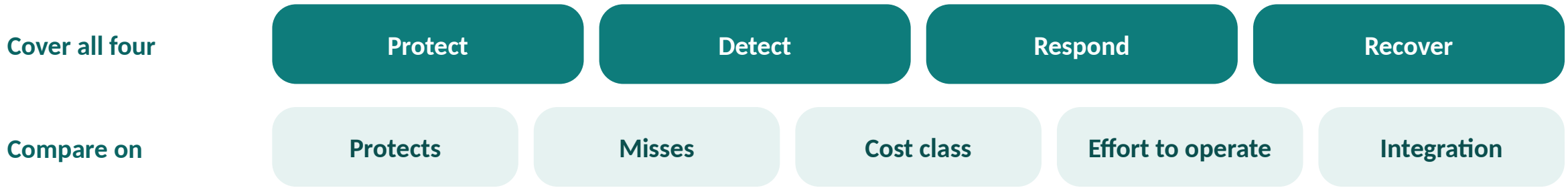
Password manager

- A unique random password per account in an encrypted **vault** (primary passphrase + **MFA** (Multi-Factor Authentication))
- Fills only on the **exact domain**: silent on bluefern-invoices.example
- Shared vaults replace the shared password BlueFern2019!
- Risk: every account at once if the vault is opened (**ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).30.025)

Patch management

- Inventory → pilot group → deployment rings → report (**NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-40 Rev. 4)
- Priorities: exposure, exploited in real attacks (**CISA** (Cybersecurity and Infrastructure Security Agency (United States)) **KEV** (Known Exploited Vulnerabilities)), **CVSS** (Common Vulnerability Scoring System) severity, asset criticality
- Limits: devices missing from the inventory, zero-days, end-of-life software
- Windows 10 support ended in October 2025

4 How to choose — from the threats, not the products



- Start from Binder Parts 3 and 6: each important threat needs a control that **prevents**, one that **detects**, and a way to **respond** and **recover** (**NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework))
- For 38 people and two **IT** (Information Technology) staff: the security built into the operating systems and cloud services, centrally managed, plus a managed service for the alerts
- The Canadian Centre's baseline controls for small organizations = the checklist of Exercise 10.3

4 Schematic 4 — where each security tool runs

Where each security tool runs and what it covers (NIST CSF functions)

	Protect	Detect	Respond	Recover
User / identity	password manager MFA	SIEM: impossible travel	account lockout	password reset
Endpoint	antivirus (known malware) patching least privilege	EDR behaviour antivirus alerts	EDR: stop process, isolate host	re-image from known-good build
Network	stateful firewall VLANs IPS (inline)	network IDS firewall logs	block address isolate VLAN	—
Application	WAF parameterized queries encoding	WAF logs application logs	virtual patch	redeploy known-good version
Central	patch management configuration baseline	SIEM correlation	SOAR playbooks MDR	incident timeline
Data	encryption access control	DLP (Sprint 2)	restrict share	offline, tested backups (Class 6)

An empty or weak cell is the reason for the next layer — choose from the threats, not from the products.

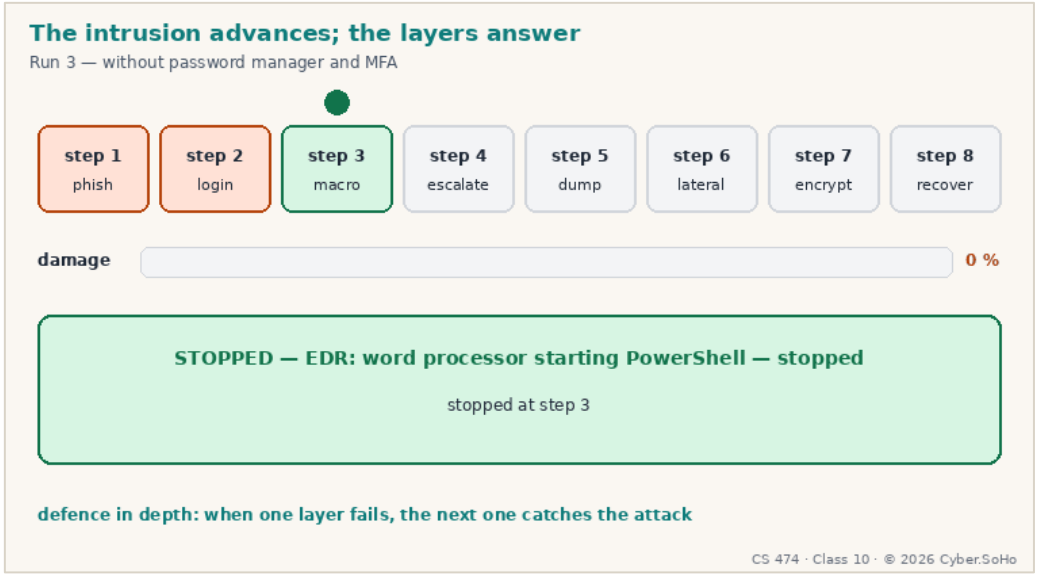
CS 474 · Class 10 · © 2026 Cyber.SoHo — fictional BlueFern Trading Inc. scenario

Rows: where the tool runs (user, endpoint, network, application, central, data). Columns: Protect, Detect, Respond, Recover (**NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework)). Each tool appears in the cells it covers — and the empty cells are the reason for the next layer.

4 Example 4 — Friday 16:40, a new ransomware variant

What happens — and where it goes next

- Step 0: fourteen commodity attachments — the antivirus blocks every one by signature
- Steps 1–8: phishing, stolen-password login, macro, privilege escalation, credential dumping, lateral movement, encryption, recovery
- Today's tools: no alert from step 1 to step 7; the attached backup drive is encrypted too
- Full set: stopped at step 1; without the password manager and **MFA** (Multi-Factor Authentication): stopped at step 3; **EDR** (Endpoint Detection and Response) isolates the file server after 312 files instead of 48,000
- Deliverable → Exercise 10.3 selection matrix; Exercise 10.1 rows



Animation 4 — The intrusion advances; the layers answer (plays in slide-show mode)

▶️ Interactive example 4 — Defence-in-depth simulator — one intrusion, eight defensive families

`CS474_Class10_Example4_defense_in_depth.html`

Self-contained **HTML** (HyperText Markup Language): Copy · Start / Pause · Step · Restart; runs offline and sends nothing

4 Micro-activity 4 — which tool for which job? (2 min)

- 1 · A brand-new ransomware variant renames 2,000 files in one minute on a finance laptop
- 2 · A staff laptop connects to port 445 of every address in the server **VLAN** (Virtual Local Area Network)
- 3 · Twelve failed **VPN** (Virtual Private Network) logins, a success from another country, a new administrator account
- 4 · A salesperson uses the same password on fourteen websites
- Bonus · The web shop still runs Apache 2.4.18 from 2016

Videos — 15 minutes or less, checked November 14, 2026

▶️ **Endpoint Security - CompTIA Security+ SY0-701 - 4.5**
Professor Messer · 9:25 · Watch on YouTube ↗

▶️ **Security Tools - CompTIA Security+ SY0-701 - 4.4**
Professor Messer · 14:06 · Watch on YouTube ↗

▶️ **Password Security - CompTIA Security+ SY0-701 - 4.6**
Professor Messer · 6:22 · Watch on YouTube ↗

LESSON 5 · 5 MINUTES OF TALK + 4 MINUTES OF ACTIVITY

5 Putting it together

BlueFern's target architecture (controls mapped to threats) and how the Research Sprints work

Objective. Assemble the controls of Lessons 1–4 into one target architecture, justify every control with a threat (control-to-threat traceability), and know exactly how the three December Research Sprints run.

5 Defence in depth → BlueFern's target architecture

People and process
training, patching, incident response, change control

Perimeter and zones
Lesson 1 — firewall, **DMZ** (Demilitarized Zone — also called a screened subnet), **VLANs** (Virtual Local Area Networks), **WAF** (Web Application Firewall)

Remote and wireless access
Lesson 2 — **VPN** (Virtual Private Network) with **MFA** (Multi-Factor Authentication), separate **SSIDs** (Service Set Identifiers)

The application
Lesson 3 — validation, parameters, encoding, sessions

Endpoints and centre
Lesson 4 — **EDR** (Endpoint Detection and Response), **IDS** (Intrusion Detection System), **SIEM** (Security Information and Event Management), password manager, patching

Recovery
Class 6 — tested offline backup

- **Defence in depth**: several **independent** layers, so that one failure does not become a breach
- Zero trust (**NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-207): assume a layer fails — authenticate every access, check the device, least privilege, watch everything
- Exercise 10.1 places these boxes on BlueFern's diagram; tracing each to a threat turns the drawing into a plan

5 Traceability — every box needs a reason

R1 **No orphan control**
every control points to a threat (Part 3) or a risk (Part 6)

R2 **No uncovered high risk**
every high risk is prevented and detected or recovered

R3 **Owner and process**
a named role and a routine for every control

R4 **The numbers agree**
Parts 1, 6 and 8 tell the same story

Two rows of BlueFern's control-to-threat table

- **WAF** (Web Application Firewall) + parameterized queries ↔ **SQL** (Structured Query Language) injection on the web shop (Part 3, Part 4 scan)
- **EDR** (Endpoint Detection and Response) + offline backups ↔ ransomware on the file server (Part 6 register)

5 How the Research Sprints work — December 3, 10 and 17

Sprint 1 · Thu Dec 3

Cyber terrorism and information warfare (Ch. 12)

Part 9 due Wed Dec 9, 23:59

Sprint 2 · Thu Dec 10

Industrial espionage and e-commerce security (Ch. 7 + **PCI** (Payment Card Industry) handout)

Part 10 due Wed Dec 16, 23:59

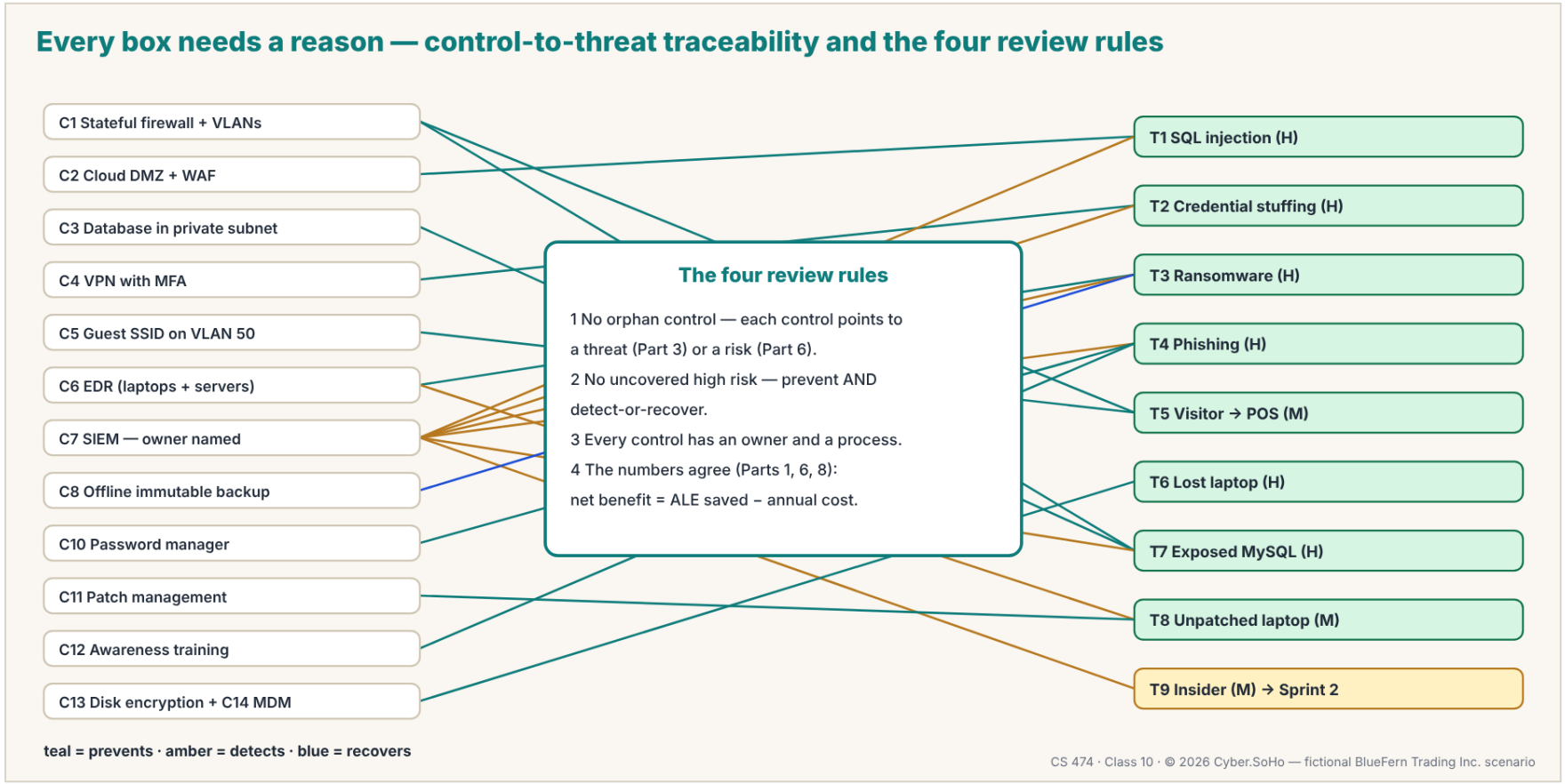
Sprint 3 · Thu Dec 17

Blockchain and decentralized applications + Binder integration workshop

Part 11 due Sun Dec 20, 23:59

- Supervised project-work sessions. **Hour 1**: guided self-study from the **Session Pack** (reading guide, 10–12-minute mini-lecture, flash-cards, self-quiz); **Hours 2–3**: team work with a template
- Questions → the course **Q&A thread**, answered within 48 hours; the **2:50 exit ticket** (draft + one line) records attendance
- Final Binder (Milestone 2): Wednesday, January 13, 2027, 23:59 — showcase Thursday, January 14

5 Schematic 5 — control-to-threat traceability

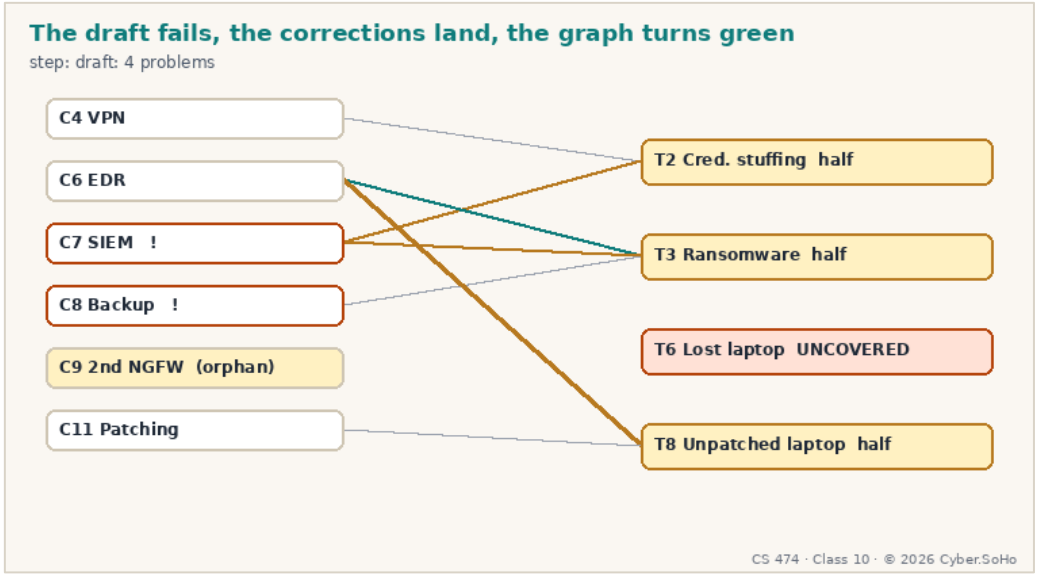


Controls on the left, threats and risks on the right; every line is prevent, detect or recover. The four review rules sit in the centre.

5 Example 5 — the architecture review before the CFO (Chief Financial Officer) meeting

What happens — and where it goes next

- A draft of twelve controls (C1–C12) checked against nine threats from the Binder
- Seven findings: an orphan **NGFW** (Next-Generation Firewall) licence, the uncovered lost laptop, no working recovery, **MFA** (Multi-Factor Authentication) “next year”, a **SIEM** (Security Information and Event Management) without owner, laptops not patched, the insider risk (→ Sprint 2)
- Fixes: C13 full-disk encryption, C14 **MDM** (Mobile Device Management), an offline immutable copy, **MFA** (Multi-Factor Authentication) now, a named **SIEM** (Security Information and Event Management) owner
- **MFA** (Multi-Factor Authentication) + **EDR** (Endpoint Detection and Response): $30,000 a year, loss $100,000 → $20,000, net benefit $50,000; disk encryption + **MDM** (Mobile Device Management): net $44,000
- Deliverable → Exercise 10.1 table; Research Sprint 3 integration; showcase



Animation 5 — The draft fails, the corrections land, the graph turns green (plays in slide-show mode)

▶️ Interactive example 5 — Traceability checker — controls ↔ threats

`CS474_Class10_Example5_traceability_checker.html`

Self-contained **HTML** (HyperText Markup Language): Copy · Start / Pause · Step · Restart; runs offline and sends nothing

5 Sprint check + Zen break (4 min)

- (a) A content question during a Sprint — where does it go, and when is it answered?
- (b) What is the 2:50 exit ticket, and what does it record?
- (c) When is Binder Part 9 due?
- Zen break: stand up, three slow breaths, eyes on a point six metres away, stretch — two minutes

Videos — 15 minutes or less, checked November 14, 2026

▶️ Network Appliances - CompTIA Security+ SY0-701 - 3.2
Professor Messer · 11:56 · Watch on YouTube ↗

▶️ Infrastructure Considerations - CompTIA Security+ SY0-701 - 3.1
Professor Messer · 13:48 · Watch on YouTube ↗

▶️ Vulnerability Remediation - CompTIA Security+ SY0-701 - 4.3
Professor Messer · 8:45 · Watch on YouTube ↗

Hours 2–3 — Binder Part 8 in three exercises

Exercise 10.1

Target architecture

Diagram after the changes + a **control-to-threat table** (Parts 3 and 6)

Method: Lessons 1, 2, 5 · Examples 1, 2, 5

Exercise 10.2

Web-shop checklist

Twelve **OWASP** (Open Worldwide Application Security Project) items + the corrected login snippet (parameters, encoding, hashes)

Method: Lesson 3 · Example 3

Exercise 10.3

Software selection matrix

Five categories × protects, misses, cost class, effort, pick

Method: Lesson 4 · Example 4

Last 15 minutes — Sprint briefing: teams confirmed, Session Packs on the **LMS** (Learning Management System), the Q&A thread, the exit-ticket rule, the dates of December 3, 10 and 17.

At home, the Binder, and what comes next

- Read the rest of Easttom Ch. 9 and skim Ch. 12 — the preparation for Research Sprint 1
- Finish **Binder Part 8**: architecture + control-to-threat table + checklist + corrected snippet + selection matrix
- Next Thursday, December 3: **Research Sprint 1** — the Session Pack is on the **LMS** (Learning Management System) from today

Wed Dec 2

Binder Part 8 due at 23:59

Why it matters: LO (Learning Outcome) 5 — “evaluate the risks faced by a given computer system” — is assessed by mapping controls to risks. Part 8 is also the “after” half of the before → after story of the Final Binder (January 13) and the showcase (January 14).

Official sources and links (1/3)

Firewalls, segmentation and network architecture

- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-41 Rev. 1 — Guidelines on Firewalls and Firewall Policy (2009) csrc.nist.gov ↗
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-215 — Guide to a Secure Enterprise Network Landscape (2022) csrc.nist.gov ↗
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-207 — Zero Trust Architecture (2020) csrc.nist.gov ↗
- Canadian Centre for Cyber Security — Network security zoning (ITSG-38) cyber.gc.ca ↗
- **IEEE** (Institute of Electrical and Electronics Engineers) 802.1 Working Group (802.1Q bridges and **VLANs** (Virtual Local Area Networks); 802.1X port-based network access control) 1.ieee802.org ↗
- **OWASP** (Open Worldwide Application Security Project) **CRS** (Core Rule Set) — the Core Rule Set for web application firewalls — **OWASP** (Open Worldwide Application Security Project) **CRS** (Core Rule Set) Project coreruleset.org ↗

Remote access and wireless

- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-77 Rev. 1 — Guide to **IPsec** (Internet Protocol Security) **VPNs** (Virtual Private Networks) (2020) csrc.nist.gov ↗
- Canadian Centre for Cyber Security — Virtual private networks (**ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).80.101) cyber.gc.ca ↗
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-153 — Guidelines for Securing Wireless Local Area Networks (2012) csrc.nist.gov ↗
- Wi-Fi Alliance — Security (**WPA3** (Wi-Fi Protected Access 3), Wi-Fi Enhanced Open) wi-fi.org ↗
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-63B-4 — Authentication and Authenticator Management (2025) csrc.nist.gov ↗

Before clicking, check any link with VirusTotal and Google Safe Browsing (Legal Notice, Annex C). All links opened on November 14, 2026.

Official sources and links (2/3)

Web-application security

- **OWASP** (Open Worldwide Application Security Project) Top 10:2025 — the ten most critical web application security risks owasp.org ↗
- **OWASP** (Open Worldwide Application Security Project) Top 10:2025 — A05 Injection owasp.org ↗
- **OWASP** (Open Worldwide Application Security Project) Top 10:2025 — A07 Authentication Failures owasp.org ↗
- **OWASP** (Open Worldwide Application Security Project) Top 10:2025 — A02 Security Misconfiguration owasp.org ↗
- **OWASP** (Open Worldwide Application Security Project) Cheat Sheet — **SQL** (Structured Query Language) Injection Prevention cheatsheetseries.owasp.org ↗
- **OWASP** (Open Worldwide Application Security Project) Cheat Sheet — Cross Site Scripting Prevention cheatsheetseries.owasp.org ↗
- **OWASP** (Open Worldwide Application Security Project) Cheat Sheet — Session Management cheatsheetseries.owasp.org ↗
- **RFC** (Request for Comments — an Internet standards document) 6797 — **HTTP** (Hypertext Transfer Protocol) Strict Transport Security (**HSTS**) — **IETF** (Internet Engineering Task Force) / **RFC** (Request for Comments — an Internet standards document) Editor rfc-editor.org ↗
- **RFC** (Request for Comments — an Internet standards document) 6265 — **HTTP** (Hypertext Transfer Protocol) State Management Mechanism (cookies) — **IETF** (Internet Engineering Task Force) / **RFC** (Request for Comments — an Internet standards document) Editor rfc-editor.org ↗

Before clicking, check any link with VirusTotal and Google Safe Browsing (Legal Notice, Annex C). All links opened on November 14, 2026.

Official sources and links (3/3)

Security software and patching

- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-83 Rev. 1 — Guide to Malware Incident Prevention and Handling for Desktops and Laptops csrc.nist.gov ↗
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-94 — Guide to Intrusion Detection and Prevention Systems csrc.nist.gov ↗
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-40 Rev. 4 — Guide to Enterprise Patch Management Planning (2022) csrc.nist.gov ↗
- Canadian Centre for Cyber Security — Password managers: Security tips (**ITSAP** (IT Security Awareness Publication of the Canadian Centre for Cyber Security).30.025) cyber.gc.ca ↗
- Canadian Centre for Cyber Security — Baseline cyber security controls for small and medium organizations cyber.gc.ca ↗
- **CIS** (Center for Internet Security) Critical Security Controls Version 8.1 cisecurity.org ↗
- **PCI** (Payment Card Industry) Data Security Standard (**PCI DSS** (Payment Card Industry Data Security Standard)) — **PCI** (Payment Card Industry) Security Standards Council pcisecuritystandards.org ↗

Law, course and safety checks

- Criminal Code of Canada, s. 342.1 — Unauthorized use of computer — Justice Laws Website laws-lois.justice.gc.ca ↗
- Criminal Code of Canada, s. 430 — Mischief (430(1.1) mischief in relation to computer data) — Justice Laws Website laws-lois.justice.gc.ca ↗
- Easttom, W. C. II — Computer Security Fundamentals, 4th ed. (Pearson) pearson.com ↗
- Cyber.SoHo — Legal Notice, Terms of Use and Acceptable Use Policy (v2.0) — Cyber.SoHo Educational Hub cyber-soho.github.io ↗
- VirusTotal — **URL** (Uniform Resource Locator) check virustotal.com ↗
- Google Safe Browsing — site status transparencyreport.google.com ↗

Before clicking, check any link with VirusTotal and Google Safe Browsing (Legal Notice, Annex C). All links opened on November 14, 2026.

Legal Notice, scope and safety

Authorization governs everything

All scanning, testing and “attack” exercises run only on the lab systems and the fictional BlueFern scenario, with explicit authorization. Unauthorized access or interference is a criminal offence — Criminal Code of Canada s. 342.1, the US Computer Fraud and Abuse Act, **EU** (European Union) Directive 2013/40/EU, Spain's Ley Orgánica 10/1995 — whatever the intent. No **OSINT** (Open-Source Intelligence) on real people or organizations.

This module's simulators

The five simulators run entirely inside your browser: they send no packets, scan nothing and contact no website. Typing an injection string into a real website, or surveying a Wi-Fi network you do not own, is not a course activity. A firewall rule on a live system needs the owner's written approval (Legal Notice 7.4).

Cyber.SoHo Legal Notice

Legal Notice, Terms of Use and Acceptable Use Policy (v2.0) open it ↗

Sections 2, 4.2–4.6, 5, 6, 7.2, 7.4, 7.6, 8, 11, 14, 17, 18, 20 and Annexes A, C and D apply to this module. The e-signature form (Annex A) is provided separately.

Check every link with VirusTotal and Google Safe Browsing before you click (Annex C).

Questions?

Thank you — that is the last new content of CS 474.

- After the break: the graded Mid-Terms, then **Exercise 10.1**
- **Binder Part 8** — Wednesday, December 2, 2026, 23:59
- **Research Sprint 1** — Thursday, December 3 · Session Pack on the **LMS** (Learning Management System)



Cyber Soho Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together ! · ALL Rights Reserverd

Educational material — Cyber.SoHo / Asen Grozdanov · Legal Notice, Terms of Use and Acceptable Use Policy (click to open)